

Università degli Studi di Napoli “Federico II”
Corso di Laurea Magistrale in Ingegneria Informatica

Software Security

Elaborato finale

Prof. Natella Roberto

Pietro Conte

Indice

1	Introduzione e Requisiti di Traccia	2
1.1	Selezione e Caratterizzazione del Campione	2
2	Analisi Statica	5
2.1	Analisi Architetturale e dell'Entropia (PE Header)	5
2.1.1	Studio delle librerie	6
2.2	Analisi del Bytecode e Assembly Information (dnSpy)	7
2.2.1	Analisi del Dropper e Meccanismo di Unpacking	7
2.3	Rilevamento delle Capacità tramite <i>capa</i>	9
2.4	Threat Intelligence e Rilevamento Euristico (VirusTotal)	10
3	Analisi Dinamica e Comportamentale	12
3.1	Setup del Laboratorio e Isolamento	12
3.1.1	Configurazione del Network Sinkholing (FakeNet-NG)	12
3.2	Inizializzazione del Processo	13
3.2.1	Attività del processo padre: lettura di MachineGuid	14
3.2.2	Ciclo di Vita e Divergenza Comportamentale	15
3.2.3	Analisi delle Cause della Divergenza	15
3.3	Neutralizzazione e Identificazione del Payload	18
4	Detection Engineering	20
4.1	Regola YARA	20
4.1.1	Prima regola: prototipo e analisi dei falsi positivi	20
4.1.2	Seconda regola: approccio multi-stadio	21
4.2	Regola Sigma	23
4.3	Utilizzo di Modelli di Linguaggio (LLM)	27
4.3.1	Modalità di Utilizzo	27

1 Introduzione e Requisiti di Traccia

Il presente documento descrive le attività svolte nel progetto di Analisi Malware, finalizzato allo studio strutturale, comportamentale e metodologico di un codice malevolo reale estratto da campagne d'attacco contemporanee.

Seguendo le linee guida del corso, il progetto si articola sui seguenti vincoli e obiettivi operativi:

- **Orizzonte temporale delle campagne:** selezione di un campione afferente a campagne d'attacco recenti, con un limite massimo non superiore ai 3 anni;
- **Contesto d'Intelligence Nazionale:** allineamento con gli scenari tracciati all'interno del **CSIRT Italia** (struttura dell'Agenzia per la Cybersicurezza Nazionale - ACN), i quali evidenziano una pervasiva diffusione di minacce di tipo *Infostealer* sul territorio italiano;
- **Metodologia d'indagine:** integrazione tra tecniche di analisi statica e tecniche di analisi dinamica, con successiva traduzione degli artefatti in regole di rilevamento (detection engineering).

1.1 Selezione e Caratterizzazione del Campione

Il campione oggetto della presente trattazione è stato individuato e prelevato dalla piattaforma pubblica di Threat Intelligence e sandbox analysis **Hatching Triage** (<https://tria.ge/>), hub di riferimento per l'analisi comportamentale automatizzata dei campioni.

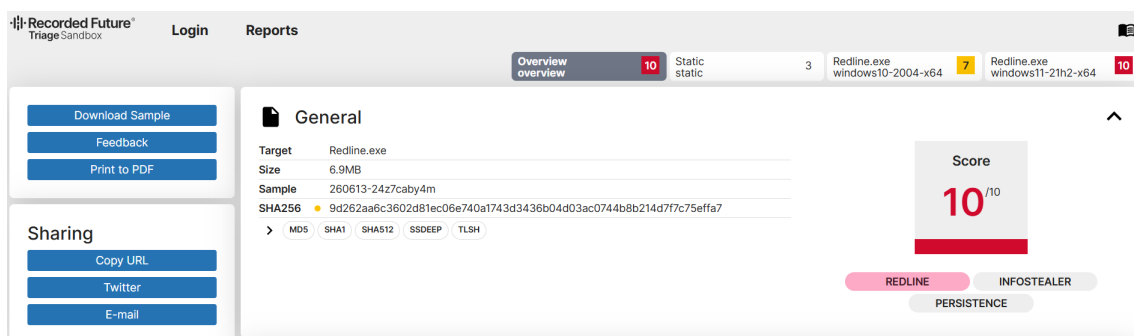


Figura 1: Campione selezionato per l'analisi

Identificazione Il file oggetto dell'indagine si presentava originariamente sotto il nome di **Redline.exe**. Come verrà dimostrato nella fase di reverse engineering (Sez. 2.2), questo file non rappresenta il codice malevolo finale, bensì funge da **Dropper**: un componente la cui logica consiste nel trasportare uno o più payload *compressi* e incapsulati nelle Resources dell'assembly, per poi decomprimerli,

rilasciarli su disco ed eseguirli in un secondo momento. Si tratta di una tecnica pensata per ostacolare l'analisi statica e i controlli antivirus basati su firma; come si vedrà nella Sez. 2.4, tuttavia, il campione è ormai ampiamente tracciato dalle firme AV moderne, a conferma della sua diffusione.

Inquadramento Tassonomico Dal punto di vista tassonomico, l'artefatto analizzato è un **dropper .NET multi-payload**. L'analisi statica e dinamica mostrerà che esso estrae ed esegue *due* distinti moduli secondari:

- un modulo identificato come **RedLine Stealer** — attribuzione confermata da VirusTotal, che vedremo più avanti;
- un modulo **ClipBanker** (Trojan:MSIL/ClipBanker!rfn), la cui identità è stata *confermata* da Microsoft Defender Antivirus durante l'analisi dinamica.

Entrambi i moduli appartengono alla macro-famiglia degli **Infostealer**: a differenza dei malware distruttivi (come i Ransomware), un Infostealer è un agente silente il cui ciclo di vita è ottimizzato per la raccolta di informazioni sensibili dall'endpoint della vittima. A seconda della variante, gli obiettivi tipici includono:

1. **Credenziali d'accesso e identità**: estrazione automatizzata di username e password;
2. **Session hijacking**: sottrazione dei cookie di sessione attivi;
3. **Asset finanziari virtuali**: scansione del file system alla ricerca di wallet di criptovalute o, come nel caso del modulo ClipBanker confermato, dirottamento degli indirizzi di wallet copiati negli appunti di sistema.

Razionale della Scelta La decisione di analizzare questo campione è scaturita da una valutazione metodologica e operativa, finalizzata a soddisfare due requisiti fondamentali della traccia:



Figura 2: Riferimento agli Infostealer nei riassunti operativi del CSIRT Italia (ACN)

- **Pertinenza con l'Intelligence Nazionale (ACN):** i bollettini operativi e i riassunti periodici del **CSIRT Italia** (ACN) indicano gli *Infostealer* come una delle minacce cyber più pervasive e in costante crescita sul territorio nazionale negli ultimi anni. Essi colpiscono indiscriminatamente sia i cittadini privati sia le infrastrutture aziendali, fungendo spesso da vettore di accesso iniziale per successivi attacchi ransomware su larga scala;
- **Valenza didattica e metodologica:** l'architettura a doppio stadio (dropper iniziale e payload multipli) e l'impiego di un assembly **.NET** con payload compressi (GZip) offrono un caso di studio ideale. Questa configurazione permette di applicare un ampio spettro di tecniche viste nel corso: dal reverse engineering del bytecode gestito (dnSpy) allo studio delle routine di decompressione, fino all'analisi comportamentale in ambiente di sandbox isolato e alla scrittura di regole di rilevamento (YARA, Sigma).

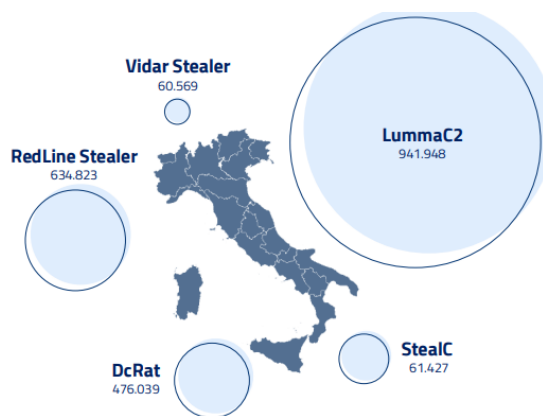


Figura 3: Prevalenza degli Infostealer in Italia

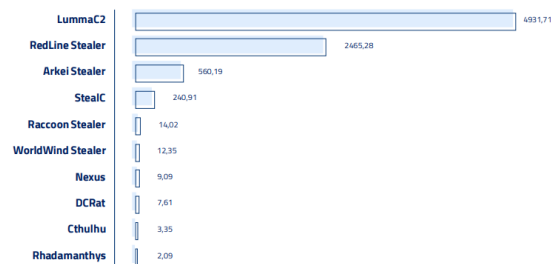


Figura 4: Distribuzione delle categorie di minaccia